



xAsset

Security Audit Report

Prepared by

OKX Web3 Audit Team

10 December 2025

Contents

1	Overview	3
1.1	Project Introduction	3
1.2	Audit Summary	3
1.3	Audit Scope	3
2	Audit Summary	4
2.1	Audit Methodology	4
2.2	Audit Process	4
2.3	Risk Classification and Description	5
2.4	Results	5
3	Vulnerabilities	7
3.1	Low - Exchange rate updates can exceed 2x maxAllowances limit	7
3.2	Informational - Insufficient allowance of callers can prevent update of exchange rate	9
4	Disclaimer	10
5	About OKX Web3 Audit Team	10

1. Overview

1.1 Project Introduction

xAssets are centralized issued ERC-20 tokens backed by OKX, containing 2 categories:

1. Wrapped Tokens (1:1 Backed)

Direct on-chain representations of underlying assets with guaranteed 1:1 backing by OKX reserves. Example: xBTC, xETH, xSOL

2. Liquid Staking Tokens (Yield-Bearing)

Tokenized staking positions that accrue staking rewards while remaining fully liquid and transferable. Example: xBETH, xOKSOL

1.2 Audit Summary

Ecosystem	EVM
Language	Solidity
Repository	https://github.com/okx/xBTC/tree/xbeth-evm
Base Commit	e8a0b80f91490166ad3fc06a24e296d95c0515ad
Final Commit	fff55a85994bd135f43ce3354aba8637dacd3fed

1.3 Audit Scope

```
contracts/
├─ ExchangeRateUpdater.sol
├─ ExchangeRateUtil.sol
├─ Proxy.sol
├─ RateLimit.sol
├─ StakedTokenV1.sol
└─ xToken.sol
```

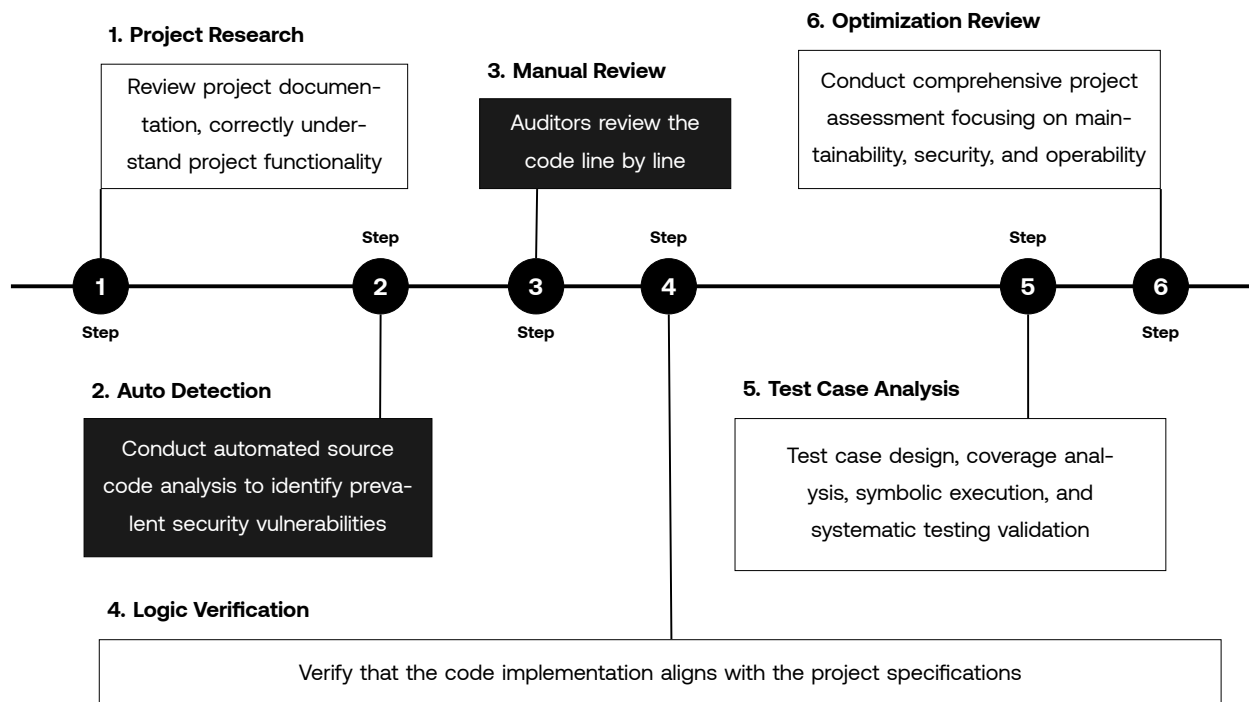
2. Audit Summary

2.1 Audit Methodology

The audit team conducted comprehensive analysis of the contract code through deep understanding of the project’s design purpose, operating principles, and implementation methods. By mapping function call relationships, potential security vulnerabilities were systematically identified, with detailed problem descriptions and corresponding remediation recommendations provided.

2.2 Audit Process

The smart contract security audit follows a 6-phase process: Project Research, Automated Detection, Manual Review, Logic Verification, Test Case Analysis, and Optimization Review. During manual auditing, auditors perform comprehensive code review to identify vulnerabilities and provide detailed solutions. After completing all phases, the lead auditor communicates findings with the project team. Following the team’s responses, we deliver final audit reports to the project team.



2.3 Risk Classification and Description

Risk items are classified into 5 levels: Critical, High, Medium, Low, and Informational. Critical risks require immediate resolution and re-audit before final report delivery; unresolved critical risks result in audit failure.

Risk Level	Risk Description
Critical	Critical risks are those that impact the safe functioning of a platform and must be addressed before launch. Users should not invest in any project with outstanding critical risks.
High	High risks can include centralization issues and logical errors. Under specific circumstances, these major risks can lead to loss of funds and/or control of the project.
Medium	Medium risks may not pose a direct risk to users' funds, but they can affect the overall functioning of a platform.
Low	Low risks can be any of the above, but on a smaller scale. They generally do not compromise the overall integrity of the project, but they may be less efficient than other solutions.
Informational	Informational errors are often recommendations to improve the style of the code or certain operations to fall within industry best practices. They usually do not affect the overall functioning of the code.

2.4 Results

The audit results are divided into two parts: one part is the vulnerability summary of the project audit, and the other part is the detailed vulnerability list.

Vulnerability Summary

Critical	High	Medium	Low	Informational	Total
0	0	0	1	1	2

Vulnerability list

No.	Severity	Vulnerability	Category	Status
1	Low	Exchange rate updates can exceed 2x maxAllowances limit	Business Logic	Fixed
2	Informational	Insufficient allowance of callers can prevent update of exchange rate	Centralization Risk	Confirmed

Status Definitions

- **Open:** The audit team has notified the project team of the vulnerability, but no reasonable remediation has been implemented.
- **Fixed:** The project team has addressed the vulnerability and the fix has been verified by the audit team.
- **Confirmed:** The project team has confirmed awareness of the vulnerability risk but considers it controllable.

3. Vulnerabilities

This section outlines the risk items identified through manual review and auditing tools. Each item includes the specific file path and code location, along with the assigned risk level.

3.1 Low - Exchange rate updates can exceed 2x maxAllowances limit

Location	File	Category	Status	Severity
Line 169 - 185	RateLimit.sol	Business Logic	Fixed	Low

Description

Under normal circumstances, allowances recover linearly over time, with off-chain systems periodically triggering `updateExchangeRate()`. The contract's design intent is to allow at most `maxAllowances` rate changes within each interval period. However, the current implementation has an allowance "accumulation" issue: after a period without rate updates, two updates can be triggered within the same block, enabling up to 2x `maxAllowances` exchange rate changes.

- At T0: `allowances = maxAllowances`, `allowancesLastSet = T0`
- No exchange rate updates occur for an intermediate period
- At T+10, for example:
 - First call to `updateExchangeRate()`: `allowances == maxAllowances`, function returns directly
 - Second call to `updateExchangeRate()` in the same block: `allowancesLastSet` remains T0, allowing full allowance recovery and another update

Related Code

```

169 function _replenishAllowance(address caller) internal {
170     if (allowances[caller] == maxAllowances[caller]) {
171         return;
172     }
173     uint256 amountToReplenish = _getReplenishAmount(caller);
174     if (amountToReplenish == 0) {
175         return;
176     }
177
178     allowances[caller] = allowances[caller] + amountToReplenish;
179     allowancesLastSet[caller] = block.timestamp;
180     emit AllowanceReplenished(

```

```
181         caller,  
182         allowances[caller],  
183         amountToReplenish  
184     );  
185 }
```

Recommendation

Update allowancesLastSet even when allowances == maxAllowances to prevent "accumulation" of allowances

Project Team Feedback

Team Response	Fixed
Re-audit Result	Confirmed

3.2 Informational - Insufficient allowance of callers can prevent update of exchange rate

Location	File	Category	Status	Severity
-	RateLimit.sol	Centralization Risk	Confirmed	Informational

Description

In extreme circumstances, all callers' allowances may be insufficient to update the exchange rate. Given the volatility of cryptocurrency markets, if exchange rate updates are not timely, systems and protocols relying on it may be significantly impacted, and trading of deposited tokens may also be affected.

Related Code

```
1 // N/A: The issue concerns off-chain operations
```

Recommendation

Ensure there are sufficient callers and allowances available at all times.

Project Team Feedback

Team Response	Acknowledged. In extreme situations, the exchangeRateUpdater owner can add new callers and set sufficiently large allowances.
Re-audit Result	Confirmed

4. Disclaimer

This audit report only covers the specific audit types stated herein. We assume no responsibility for unknown security vulnerabilities outside this scope.

We rely on audit reports issued before existing attacks or vulnerabilities are published. For future or new vulnerabilities, we cannot guarantee project security impact and assume no responsibility.

Our security audit analysis should be based on documents provided by the project before report release (including contract code). These materials should not contain false information, tampering, deletion, or concealment. If provided materials are false, inaccurate, missing, tampered, deleted, concealed, or modified after report release, we assume no responsibility for resulting losses and adverse effects.

The project team should understand our audit report is based on provided materials and current technical capabilities. Due to institutional technical limitations, our report may not detect all risks. We encourage continued testing and auditing by the development team and stakeholders.

The project team must ensure compliance with applicable laws and regulations.

The audit report is for reference only. Its content, acquisition methods, usage, and related services cannot serve as basis for investment, taxation, legal, regulatory, or construction decisions. Without our prior written consent, the project team may not reference, cite, display, or distribute report content to third parties. Any resulting losses shall be borne by the project team.

This report does not cover contract compiler bugs or scope beyond programming languages. Smart contract risks from underlying vulnerabilities should be borne by the project team.

Force majeure includes unforeseeable, unavoidable events like wars, natural disasters, strikes, epidemics, and legal/regulatory changes preventing contract performance. When occurring, neither party breaches contract obligations. For unaffected economic responsibilities, the project team should pay for completed work.

5. About OKX Web3 Audit Team

OKX Web3 Audit Team specializes in blockchain security with expertise in smart contract auditing, token security assessment, and Web3 security tool development. We provide comprehensive security solutions for OKX's internal Web3 projects, conduct pre-listing token audits, and develop security tools to protect OKX Web3 wallet users. Our team combines automated analysis with manual review to deliver thorough security assessments and maintain the highest security standards in the Web3 ecosystem.